Модуль: аутентификация и сессии

1. Назначение и границы

Регистрация, вход, сессионные cookie, проверка роли, админ-вход по коду. Не делает: не управляет заявками (это квиз) и не отправляет письма.

2. Сценарии использования

- Регистрация по телефону, нику и паролю → cookie-сессия на 7 дней.
- Вход существующего пользователя; выход удаляет запись сессии.
- Проверка занятости телефона до регистрации.
- Админ-вход по коду из окружения; при отсутствии кода — 503.
- Отказ: дубликат телефона/ника → 409; слабый пароль → 400.

3. Контракт

`/api/auth/{check-phone,register,login,admin-login,logout,current-user,users}`. Модели — Pydantic (`LoginRequest`, `RegisterRequest`, `AdminLoginRequest`).

4. Данные

Пишет в `users` и `sessions`. Пароли — только хеш; сессии привязаны к пользователю.

5. Права

Роль `user` по умолчанию; `admin` — только через админ-вход с кодом из `ADMIN_CODE` (сравнение постоянного времени). Список пользователей и заявок закрыт ролью админа.

6. Зависимости

Исходящие: SQLite, `hashlib/secrets`. Входящие: страницы `/`, `/admin`, весь `/api/*`.

7. Конфигурация

`ADMIN_CODE` (обязателен для админ-входа), `DB_PATH`, `CORS_ORIGINS`.

8. Сборка и отладка

```
make test
python -m pytest tests/test_auth.py tests/test_security.py -q
```

9. Тесты

`tests/test_auth.py`: регистрация → сессия, текущий пользователь, дубликат (409), слабый пароль (400), выход, админ-вход с неверным кодом (401) и верным (200). `tests/test_security.py`: нет пароля в коде, нет CORS со звёздочкой при credentials.

10. Наблюдаемость

Ошибки маршрутов — в stdout. Ключевой сигнал: всплеск 401/409. Аудит действий пользователей не ведётся (ограничение).

11. Ограничения и готовность

- Нет восстановления пароля и подтверждения телефона.
- Нет ограничения попыток входа (rate limit) — риск перебора.
- Готовность: админ-доступ невозможен без явной конфигурации; поведение покрыто тестами.